

Sechs Empfehlungen zur Weiterentwicklung des Souveränitätskriterienkatalogs

Einreicherin	Carola Klessen, Berlin · info@vivodepot.de
Kontext	Gründerin und Maintainerin von Vivodepot (EURL-1.2, gitlab.opencode.de/oc000142426528/vivodepot)
Datum	14. Mai 2026

Vorbemerkung

Diese Stellungnahme basiert auf der Implementierungserfahrung einer offline-fähigen Einzeldatei-HTML-Anwendung zur Bürgerdaten-Souveränität (Vivodepot, EURL-1.2). Im Rahmen einer Selbstbewertung nach dem ZenDiS-Diskussionspapier wurden alle 20 Kriterien in 4 Kategorien geprüft; die vollständige Bewertungstabelle findet sich im Anhang. Die Implementierungspraxis hat sechs Aspekte des Kriterienkatalogs sichtbar gemacht, die aus unserer Sicht einer Weiterentwicklung bedürfen. Diese Aspekte bilden den Gegenstand der nachfolgenden Empfehlungen.

Empfehlungen

1. Bürgeranwendungen in den Kriterienkatalog aufnehmen

Der Kriterienkatalog richtet sich derzeit an Behörden und öffentliche IT-Infrastrukturen. Digitale Souveränität entscheidet sich aber zunehmend auch auf der Seite der Bürgerinnen und Bürger: Gesundheitsdaten, Vollmachten, Finanzdokumente und digitale Identitäten werden mit digitalen Werkzeugen verwaltet, die denselben Souveränitätsanforderungen genügen sollten wie Behördensysteme. Die Implementierungserfahrung zeigt, dass sich die 20 Kriterien sinngemäß auf Bürgeranwendungen übertragen lassen — einzelne Kriterien (etwa A2 IT-Governance) setzen jedoch implizit eine Organisationsstruktur voraus, die bei kleinen Open-Source-Projekten anders aussieht als in einer Behörde. Eine explizite Erweiterung des Rahmens würde die Debatte um digitale Souveränität auf die Ebene heben, auf der sie letztlich entschieden wird.

2. Offline-Fähigkeit als eigenständiges Kriterium definieren

Der aktuelle Katalog behandelt Offline-Fähigkeit implizit unter D1 (Betriebsabhängigkeit) und D4 (Resilienz). Vollständige Offline-Fähigkeit — also der Betrieb ohne jede Netzwerkverbindung — ist jedoch mehr als ein Teilaspekt von Resilienz: Sie ist eine eigenständige Architekturentscheidung mit Konsequenzen für Datenschutz, Lieferkette, Betriebsabhängigkeit und Datenlokation gleichzeitig. In Katastrophenschutzszenarien, bei Infrastrukturausfällen und in kritischen Lebenssituationen (Krankenhaus, Pflegeheim, Notaufnahme) ist Offline-Fähigkeit keine Komfortfunktion, sondern eine Grundbedingung verlässlicher digitaler

Handlungsfähigkeit. Ein eigenes Kriterium würde diese Dimension sichtbar machen und zur Diskussion stellen, welche Anwendungsklassen Offline-Fähigkeit zwingend erfordern.

3. EUPL-1.2 als bevorzugte Lizenz für souveräne Anwendungen empfehlen

Unter den Projekten auf openCode sind nach unserem Eindruck nur wenige unter EUPL-1.2 lizenziert. Die europäische Public Licence ist juristisch in der EU verankert, kompatibel mit GPL und anderen Copyleft-Lizenzen und stellt sicher, dass bei Einstellung eines Projekts der Quellcode frei verfügbar bleibt und von anderen öffentlichen oder zivilgesellschaftlichen Akteuren weiterentwickelt werden kann. Für Anwendungen im öffentlichen Interesse, die Langlebigkeit und Mission-Continuity erfordern, ist EUPL-1.2 aus unserer Sicht die geeignetste verfügbare Lizenz. ZenDiS könnte prüfen, ob eine entsprechende Empfehlung in den Kriterienkatalog aufgenommen werden sollte.

4. Kryptographische Vertrauensketten für Stellvertreter-Szenarien als Kriterium

In vielen kritischen Lebenssituationen handeln nicht Betroffene selbst, sondern Stellvertreterinnen und Stellvertreter: Bevollmächtigte, pflegende Angehörige, rechtliche Betreuerinnen. Diese müssen nachweisbar im Auftrag handeln können, ohne dass ein Intermediär den Nachweis vermittelt. Kryptographische Vertrauensketten ermöglichen serverlose, prüfbare Autorisierungsnachweise. Der aktuelle Kriterienkatalog berücksichtigt diese Dimension nicht. Ein Qualitätsmerkmal für Stellvertreter-Nachweisbarkeit — unabhängig von der konkreten Implementierung — würde eine strukturelle Lücke schließen, die insbesondere für Gesundheits- und Pflegeanwendungen relevant ist.

5. EUDIW-Kompatibilität als Kriterium in den Katalog aufnehmen

Mit dem Rollout der EU Digital Identity Wallet ab 2027 entsteht eine staatliche Identitätsinfrastruktur, die Behörden- und Bürgeranwendungen gleichermaßen betrifft. Die Kombination aus staatlich ausgestellten Nachweisen (Wallet) und bürgergehaltenen Lebensdaten (lokale Werkzeuge) wird die Grundarchitektur digitaler Handlungsfähigkeit in Deutschland und der EU verändern. EUDIW-Kompatibilität — konkret: die Fähigkeit, SD-JWT-VC-Nachweise zu empfangen und offline zu verarbeiten — als Kriterium im Souveränitätskatalog würde signalisieren, dass der Rahmen diese kommende Infrastruktur mitdenkt, statt sie als nachträgliche Ergänzung zu behandeln.

6. Citizen Digital Twin als konzeptionelle Anwendungsklasse berücksichtigen

Der Souveränitätskriterienkatalog bewertet Produkte und Infrastrukturen, nicht Konzepte. Dennoch fehlt im aktuellen Rahmen eine Einordnung für Anwendungen, die als persönlicher digitaler Zwilling des Bürgers funktionieren: portable, verschlüsselte, offline-fähige Datenbehälter, die ausschließlich von der betroffenen Person kontrolliert werden. Das Konzept des Citizen Digital Twin ist in der Forschungsliteratur etabliert (Kopponen et al., IEEE Internet Computing, Bd. 26, Nr. 5, 2022, DOI: 10.1109/MIC.2022.3159683) und wurde im finnischen AuroraAI-Programm national erprobt. Die dort eingesetzten Modelle waren serverbasiert und scheiterten an Adoptions- und Datenschutzhürden. Eine offline-first Variante — der Twin liegt beim

Bürger, nicht beim Betreiber — adressiert genau diese Hürden architektonisch. Der Souveränitätskatalog könnte diese Anwendungsklasse als eigenständige Kategorie einordnen und damit einen Bewertungsmaßstab schaffen, der über die bisher adressierten Behördensysteme hinausgeht.

Anhang: Selbstbewertung nach ZenDiS-Kriterienkatalog

Ergebnis: 18 von 20 Kriterien maximal erfüllt, 2 Kriterien hoch erfüllt (A2, D5). Vollständige Dokumentation: gitlab.opencode.de/oc000142426528/vivodepot → SOVEREIGNTY.md

Kriterium	Bewertung	Begründung (Kurzfassung)
A1 Strategie	Maximal	Alle Daten ausschließlich lokal. Souveränität ist Architekturkonsequenz, kein Feature.
A2 IT-Governance	Hoch	Kein Drittanbieter. Einschränkung: Ein-Personen-Projekt, kein formales Code Review. ADRs dokumentieren alle Entscheidungen. Externer Code Review als NGI Zero Meilenstein geplant.
A3 Risikomanagement	Maximal	Alle Abhängigkeiten inline. Keine Laufzeit-APIs.
A4 Beschaffung	Maximal	EUPL-1.2. Kein Vendor-Lock-in, kein Abo, dauerhaft kostenlos.
A5 Auftraggeberfähigkeit	Maximal	Quellcode vollständig einsehbar und forkbar.
A6 Kompetenzen	Maximal	Einzeldatei ohne Build-System. Über 2.300 automatisierte Tests.
B1 Transparenz	Maximal	README, DOCS, CHANGELOG, SECURITY, SOVEREIGNTY, ADRs — öffentlich.
B2 Lieferkettensicherheit	Maximal	Vier MIT-Bibliotheken inline. CycloneDX-SBOM. Kein automatischer Netzwerkkontakt.
B3 Architektur	Maximal	Eine HTML-Datei. Vollständige Migrationskette. JSON-Vollexport jederzeit.
B4 Standards	Maximal	FHIR R4/IPS, SD-JWT-VC, W3C VC, ISO 20022, XMeld, XDSC v1.1.0, FiDA (Platzhalter), ATC, ICD-10-GM, UCUM, vCard 4.0, PDF/A.
B5 Abhängigkeiten	Maximal	Keine proprietären Abhängigkeiten. Kein App-Store.
C1 Datenlokation	Maximal	100 % lokal. Kein Server, keine Cloud.
C2 Datensicherheit	Maximal	AES-256-GCM, PBKDF2-SHA256 600 000 Iter. JWS Ed25519/ES256.
C3 Datenschutz	Maximal	Kein Netzwerkkontakt — strukturell, nicht durch Policy.
C4 Datenstrukturen	Maximal	30 Import-Export-Kanäle in offenen Formaten. FiDA-Kategorie vorbereitet.
D1 Betriebsabhängigkeit	Maximal	Vollständig offline auf jedem Gerät mit Browser.
D2 Kundenverhältnis	Maximal	Kein Vertrag, keine Registrierung, kein Abo.
D3 Exit-Fähigkeit	Maximal	Die HTML-Datei ist die Anwendung. JSON-Vollexport jederzeit.
D4 Resilienz	Maximal	Offline-fähig. Trust Chain ohne EUDIW-Verbindung funktionsfähig.
D5 Sicherheit & Compliance	Hoch	Web Crypto API (browser-nativ). DSGVO by Design. Einschränkung: Kein Penetrationstest, kein externes Audit. Code Review als NGI Zero Meilenstein budgetiert.